

CYBE 435

Computer Incident Response

Lecture 2:

Preparation and Planning

Announcements

- National Cyber League Registration
 - Go to: <https://cyberskyline.com/events/ncl/welcome>
 - Create an Account
 - Go the registration link and use the individual passkey I will send you to register
- Details of first Quiz and first homework assignment coming Thursday.

Major Items to consider in Preparation and Planning

- Governance & Planning
- Prevention and Detection
- Communication & Coordination
- Training and Exercises
- Technical Readiness
- Legal and Compliance

Coordination & Planning

- Define Roles and Team Structure
 - Technical staff, Information Security Leadership, Communications, Legal, Executive
 - Division of responsibility between Information Technical and Information Security offices
- Support and Prioritization from Organization's leadership
- An Incident Management Plan

Outline of Computer Incident Response Policy (from NIST SP 800-61rev3)

- Statement of management commitment
- Purpose and objectives of the policy
- Scope of the policy (i.e., to whom and what it applies and under what circumstances) NIST SP 800-61r3 Incident Response Recommendations and April 2025 Considerations for Cyber Risk Management 9
- Definition of events, cybersecurity incidents, investigations, and related terms
- Roles, responsibilities, and authorities, such as which roles have the authority to confiscate, disconnect, or shut down technology assets
- Guidelines for prioritizing incidents, estimating their severity, initiating recovery processes, maintaining or restoring operations, and other key actions
- Performance measures

WVU Computer Incident Management Policy

- <https://wvu-privacy.my.onetrust.com/policies/f46cbaf3-1ebd-4644-ad0c-11a7304f6185?context=eyJkc1BvcnRhbnRlclljojOWI2YWZiZTA5YTdhNS00MmM5LWE3ZjEtZjAxNDc2OGYzOWM1In0%3D>
- **1. Purpose and Scope:**
- 1.1. The purpose of this Policy is to establish the rules that govern the response to Computer Security Incidents (“Security Incidents”) that occur at West Virginia University, West Virginia University Institute of Technology, and Potomac State College of West Virginia University (collectively known as “University”).
- 1.2. This Policy applies to Computer Security Incidents that pose a threat to University Information Systems or University Data. This Policy does not include the following:
 - 1.2.1. Losses of or damage to a University Information System or University Data caused by natural disasters or power failures;
 - 1.2.2. Detected vulnerabilities to University Information Systems. See Vulnerability Management Standard; or,
 - 1.2.3. Personally-owned computer assets that do not contain University Data.

Prevention and Detection

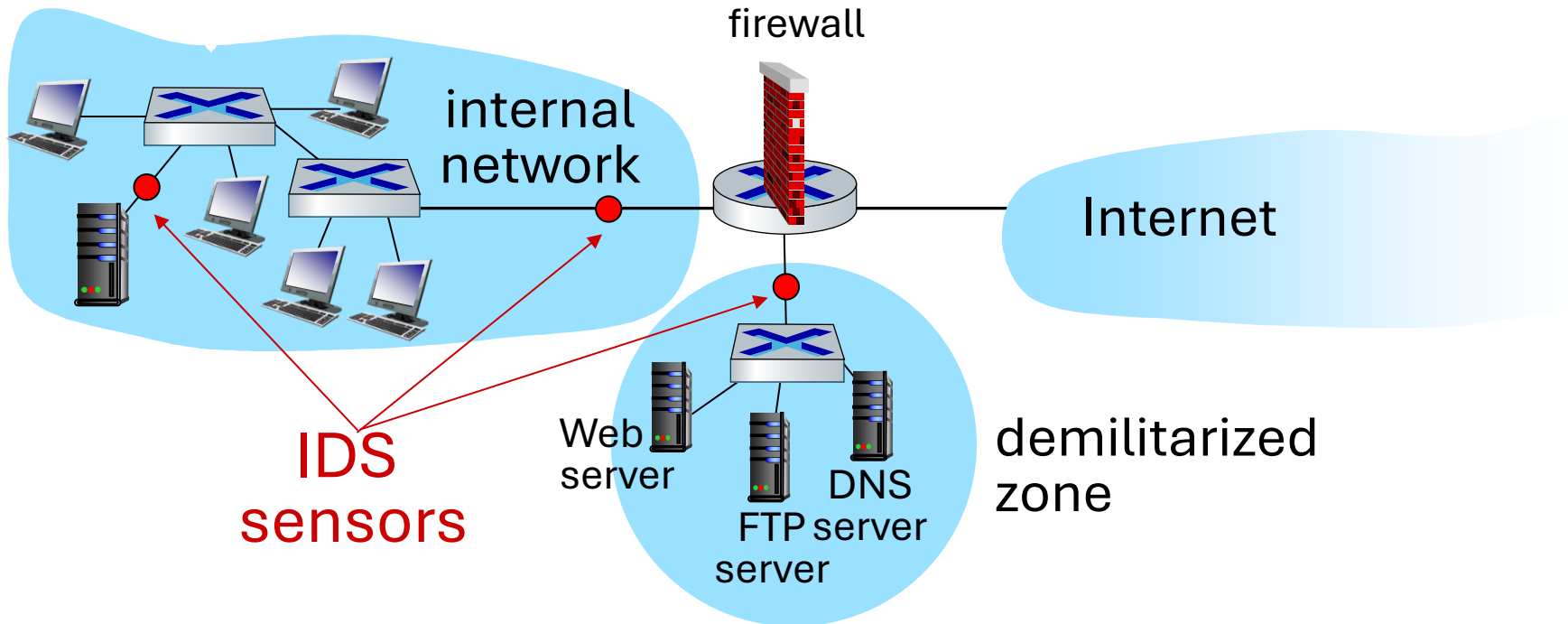
- Asset Inventory
 - What systems, devices and data do you have?
 - Which data and systems are the highest priority
 - Risk management plans might be based on both likelihood and severity
 - System Backups
- Threat Monitoring
 - Intrusion Detection Systems
 - Logging of Information
- Reducing Vulnerabilities
 - Patching of software and operating systems
 - Penetration Testing

Intrusion detection systems

- packet filtering:
 - operates on TCP/IP headers only
 - no correlation check among sessions
- IDS: intrusion detection system
 - deep packet inspection: look at packet contents (e.g., check character strings in packet against database of known virus, attack strings)
 - examine correlation among multiple packets
 - port scanning
 - network mapping
 - DoS attack

Intrusion detection systems

multiple IDSs: different types of checking at different locations



[Figure from Kurose & Ross, "Computer Networking: A top down approach," 8th edition]

Communications and Coordination

- Internal Communications Protocol
 - Who is contacted and how do they communicate securely during an incident?
- External Communications plan
 - Customers, the media
 - Pre-drafted messages?
 - Law enforcement and regulatory contacts?

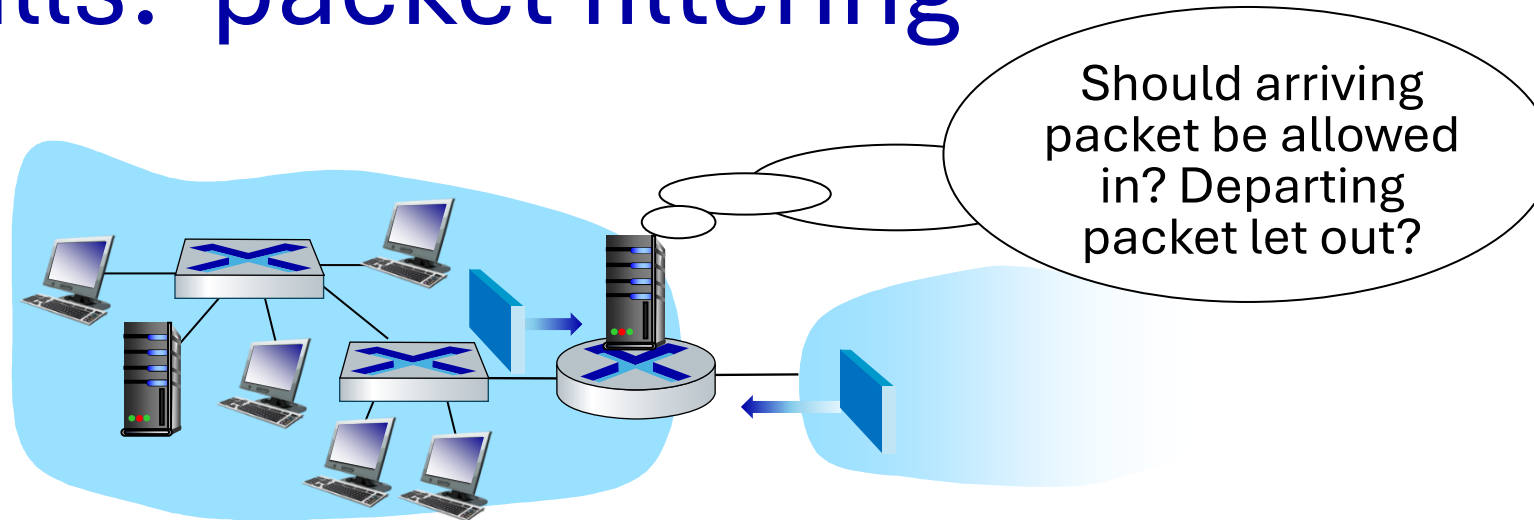
Training & Exercises

- Technical Drills
 - Security staff rehearses responses to different types of threats
- Staff Awareness Training
 - Reduces vulnerability to phishing and social engineering type attacks
 - May be required by Cyber Insurance

Technical Readiness

- Backup & Recovery
 - Critical Data
 - Offsite or in the cloud?
- Segmentation and Access Controls
 - Firewalls
 - Logging of Information
- Preservation of Logs

Firewalls: packet filtering



[Figure from Kurose & Ross, "Computer Networking: A top down approach," 8th edition]

- internal network connected to Internet via router **firewall**
- filters **packet-by-packet**, decision to forward/drop packet based on:
 - source IP address, destination IP address
 - TCP/UDP source, destination port numbers
 - ICMP message type
 - TCP SYN, ACK bits

Access Control Lists

ACL: table of rules, applied top to bottom to incoming packets:
(action, condition) pairs: looks like OpenFlow forwarding (Ch. 4)!

action	source address	dest address	protocol	source port	dest port	flag bit
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	---
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	----
deny	all	all	all	all	all	all

Legal and Compliance

- Regulatory Requirements
 - HIPAA (health), FERPA (education), Consumer Credit Protection Act
- Contracts
 - Federal and other contracts may contain specific requirements for data protection
- Insurance